

KARTA PROJEKTU

Przedmiot: Bezpieczeństwo aplikacji internetowych | Akademia WSB | edycja 2026

CEL: zbudować / zbadać rozwiązanie, wykazać ryzyko, wdrożyć zabezpieczenie i potwierdzić skuteczność w re-teście.

1. Zespół	Imię i nazwisko / nr albumu / rola w projekcie Jaromir Malina 49951 Daniel Pejs 53398 Adrian Szymczyk 48061 Przemysław Rozmanowski 53873
2. Temat projektu	ID P1–P12 lub własny temat zaakceptowany przez prowadzącego P7 – Utwardzanie przeglądarki 2026 (Browser Hardening) Kontrolowana demonstracja XSS i CSRF oraz wdrożenia zabezpieczeń w aplikacji webowej.
3. Problem i cel bezpieczeństwa	Jakie ryzyko / kontrolę badamy? Jaka zmiana ma być efektem projektu? Problem: XSS może wykonać niepożądany kod w przeglądarce, a CSRF wymusić żądanie w aktywnej sesji użytkownika. Cel: wykazać te ryzyka w laboratorium, wdrożyć zabezpieczenia i potwierdzić ich działanie testami BEFORE/AFTER.
4. Scope testów	IN SCOPE / OUT OF SCOPE; aplikacja, endpointy, konta, dane testowe; wyłącznie autoryzowane środowisko laboratoryjne IN SCOPE: własna aplikacja lokalna; jedna kontrolowana ścieżka XSS, formularz zmieniający dane oraz sesja testowa. Testy: własne konto i fikcyjne dane; przeglądarka, DevTools oraz OWASP ZAP/Burp Community. Tylko localhost. OUT OF SCOPE: serwisy publiczne, cudze konta i dane, testy poza środowiskiem jednoznacznie autoryzowanym.
5. Środowisko i technologie	Architektura, framework, kontenery/VM, narzędzia; sposób odtworzenia środowiska Proponowany stack: Node.js + Express, prosty frontend HTML/CSS/JavaScript; lokalne repozytorium Git. Zabezpieczenia: bezpieczne renderowanie danych, token CSRF, CSP i nagłówki HTTP; cookies HttpOnly, Secure, SameSite. Odtwarzanie: instrukcja README, plik zależności i skrypt uruchomienia; HTTPS lokalne do testu flagi Secure.

6. Hipoteza i scenariusze testowe	Co spodziewamy się wykazać? Jakich 3–6 kluczowych testów wykonamy? Hipoteza: bezpieczne renderowanie, walidacja tokenu CSRF, CSP i właściwe cookies ograniczą wykonanie XSS i żądania CSRF. T1–T2: payload XSS w wersji podatnej wykonuje się; po poprawce jest traktowany jako tekst i nie wykonuje. T3–T6: CSRF bez tokenu i z błędnym tokenem jest odrzucony; poprawne żądanie działa; sprawdzamy CSP i flagi cookies.
--	---

Wymagane odniesienia

Minimum dwa uznane odniesienia: jedno do wymagań / ryzyk i jedno do weryfikacji.

☒ OWASP Top 10:2025	☒ OWASP ASVS 5.0.0	☒ OWASP WSTG 4.2	☐ OWASP API Top 10:2023
☐ NIST SSDF 1.1	☐ STRIDE	☐ CWE / CVSS	☐ inne:

Definition of Done — warunki akceptacji projektu

☐ 1. Legalny scope	Wszystkie testy w środowisku własnym, celowo podatnym albo jednoznacznie autoryzowanym.
☐ 2. Reprodukowalność	Repozytorium / instrukcja pozwala uruchomić środowisko i odtworzyć scenariusz.
☐ 3. Dowód techniczny	Zespół pokazuje realny problem lub kontrolę: request/log/screen/test/code — nie tylko opis.
☐ 4. Remediacja	Wdrożona poprawka, hardening, konfiguracja albo kompletna propozycja architektoniczna.
☐ 5. Re-test	Powtórzenie kluczowych testów po zmianie i porównanie wyniku BEFORE → AFTER.
☐ 6. Mapowanie i ryzyko	Minimum dwa standardy/metodyki + ocena ryzyka i uzasadnienie priorytetu.
☐ 7. Raport i evidence	Raport 8–12 stron + materiał dowodowy / kod / konfiguracje / diagramy w repo.
☐ 8. Obrona	10–12 min prezentacji + demo + pytania; każdy członek zespołu rozumie cały projekt.

Harmonogram

04.10.2026	18.10.2026	25.10.2026	21.11.2026
KICK-OFF zespół + temat + scope	CHECKPOINT środowisko + model + evidence	PREFEROWANE ZALICZENIE demo + raport + repo + retest	TERMIN KOŃCOWY poprawki / projekty niezaakceptowane

Proponowany mikrotermin: Karta projektu v0.1 do 11.10.2026.

Matryca feedbacku (100 pkt)

Zakres + threat model	15	jasny cel, zasoby, powierzchnia ataku, hipoteza
Testy i dowody	25	jakość scenariuszy, evidence, powtarzalność
Remediacja + re-test	20	jakość poprawki i dowód skuteczności
Standardy + ryzyko	15	mapowanie i priorytetyzacja
Repo + raport	15	reprodukowalność, dokumentacja, jakość artefaktów
Obrona + wkład	10	zrozumienie, demo, odpowiedzi i wkład indywidualny

AKCEPTACJA PROJEKTU = ZALICZENIE PRZEDMIOTU

Punkty wspierają informację zwrotną; niespełnienie krytycznej bramki Definition of Done oznacza konieczność poprawy.